Threat Prioritization
Candidate Slicing Procedure

Revision

Version 1
10/14/26 2:12 PM

Author

Charles Wilson

Abstract

This document describes the procedure used to perform the threat candidate slicing activity described in the **AVCDL** [1] **Threat Prioritization Plan** [2] secondary document.

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to have formal processes in place regarding the disposition of cybersecurity-related threats in the context of the development of safety-critical, cyber-physical systems.

Note: Within the context of this document, the terms ***security*** and ***cybersecurity*** are used interchangeably. It is presumed that the term ***security*** is being used in reference to ***cybersecurity*** and not ***physical security***.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

https://creativecommons.org/licenses/by/4.0/legalcode

Audience

The audience of this document is the cybersecurity practitioner who will be conducting the threat candidate slicing activity within the threat prioritization process.

Completeness of Output

Since threat candidate slicing is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the security SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

When information is not available for either a given section of the template or parts thereof, this should be noted. Major omissions should be recorded in the cybersecurity risk register.

Disposition of Output

The output of this activity is used as input to either the **risk domains consolidation** activity or issue tracking system.

Once completed, the generated report should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of threat candidate ranking. Further, that the reader has read and understood the following AVCDL documents:

- **Theat Prioritization Plan** secondary document
- **Threat Prioritization – Candidate Ranking Procedure** [3] tertiary document
- **Threat Prioritization – Candidate Risking Procedure** [4] tertiary document

Prerequisites – Security SME

Qualifications

It is required that the security SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in the **NCWF Roles - Security Architect** section of the **AVCDL Background Material** elaboration document [5].

Knowledge

It is required that the security SME understands the purpose of threat candidate slicing.

Background Information

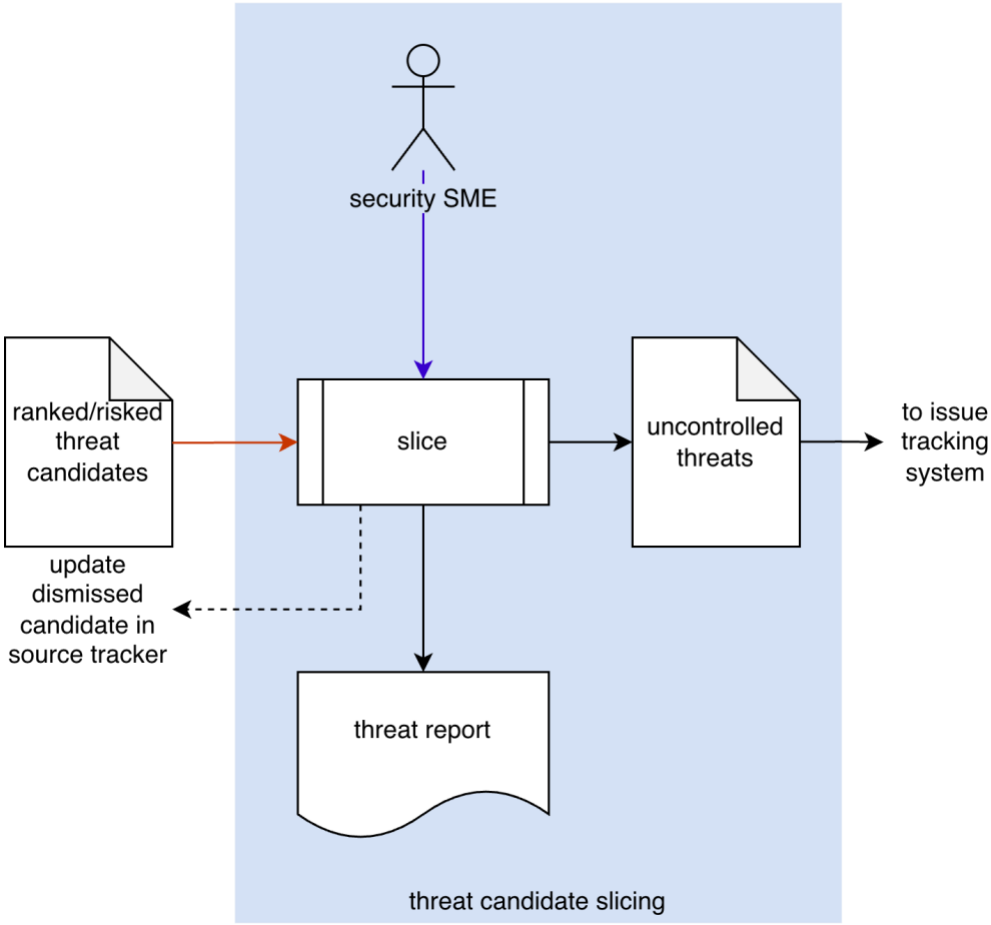
It is required that the cybersecurity SME has read and understands the AVCDL documents listed above. Additionally, that the cybersecurity SME has taken training relevant to this activity.

Prerequisites – Input Materials

It is required that the security SME acquire any documentation relevant to the threat candidates under consideration necessary to complete the procedure.

Candidate Slicing Activity

The workflow diagram for the **threat candidate slicing** activity of the **threat prioritization process** is shown below.



The **security SME** takes the **ranked/risked threat candidates** and conducts a slicing operation on them to determine which are uncontrolled, generating a list of **uncontrolled threats**. These are entered into the issue tracking system. All threat candidates deemed to be controlled are dismissed and their source tracker is updated. A **threat report** is produced.

Note: It is the responsibility of the standard issue management process to disposition uncontrolled threats by applying standard treatments (avoid, reduce, share, retain). This includes documenting the risk aspects of the issue and the reason for the disposition.

Note: If threat candidates are being considered by multiple risk domains, the **uncontrolled threats** should be sent to the **risk domain consolidation** activity.

Methodology

The recommended methodology for this activity is as follows:

1. Select a risk appetite
2. Plot the threat candidates
3. Dismiss candidates determined to be controlled
4. Prioritize the uncontrolled threats

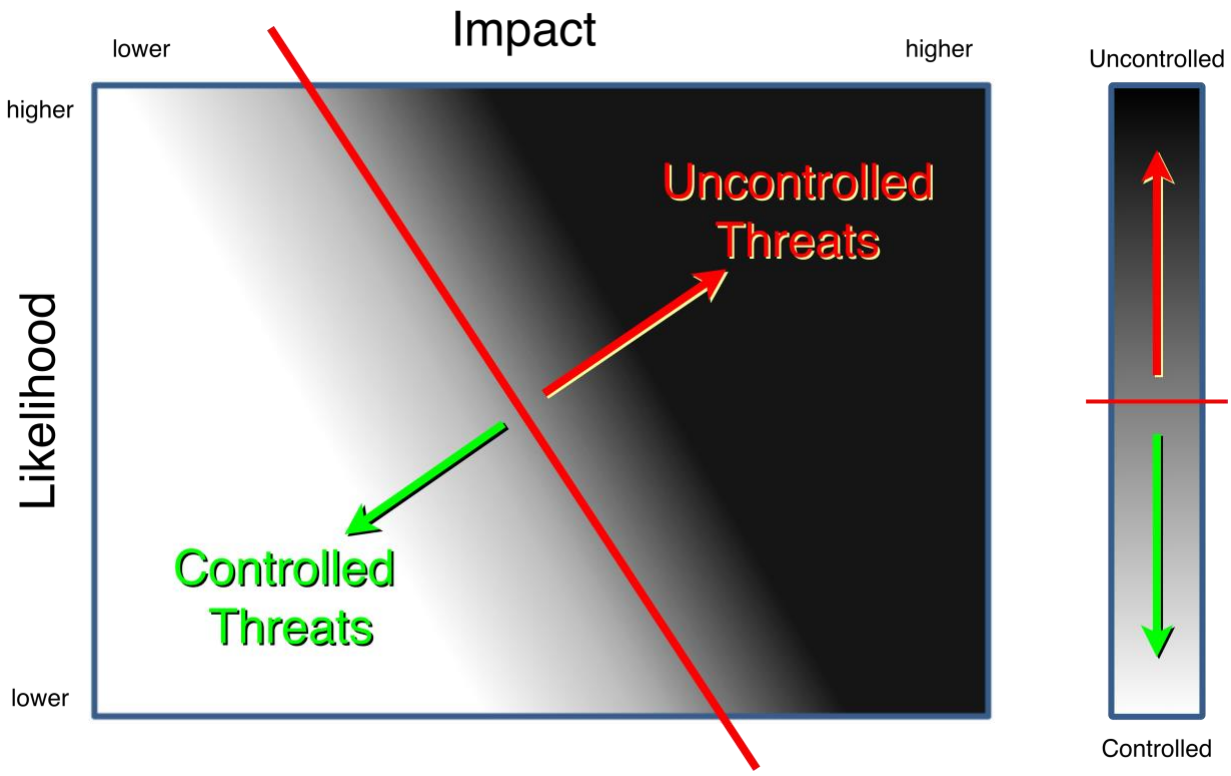
Discussion

This section provides additional information to assist in performing this activity.

Risk Space - Continuous

In the ranking and risking activities, each of the threat candidates was assigned a likelihood and impact. The threat candidates can be plotted within a space with likelihood on one axis and impact on the other.

This can be visualized as follows:



Note: Adapted from **Postmarket Management of Cybersecurity in Medical Devices** [10].

The risk is shown as continuous greyscale.

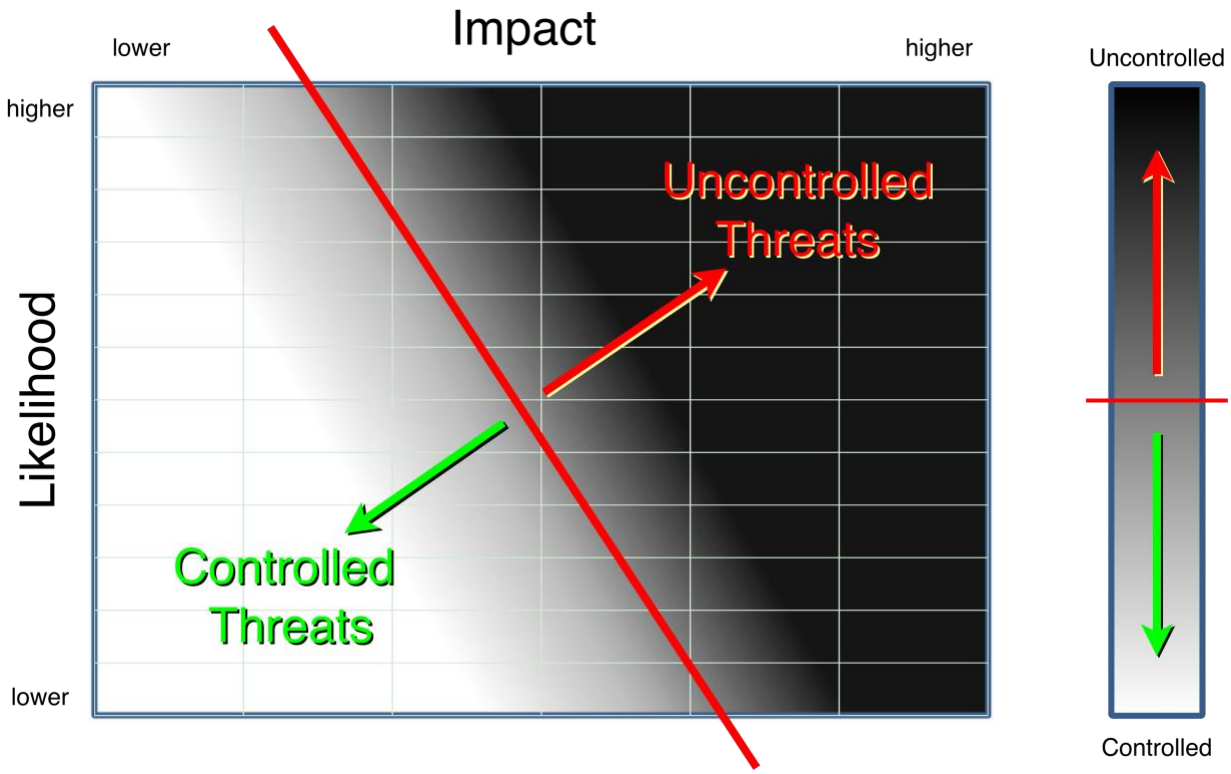
The red line represents the organization's risk appetite. This is used to slice (bisect) the space with those threat candidates above and to the right of the line being uncontrolled (requiring mitigation) and those below, controlled (not requiring mitigation).

The view on the right shows a simplified representation of this.

Risk Space - Quantized

When the likelihood and impact values are quantized it has the effect of reducing all threats into a lower resolution space.

This can be visualized as follows:



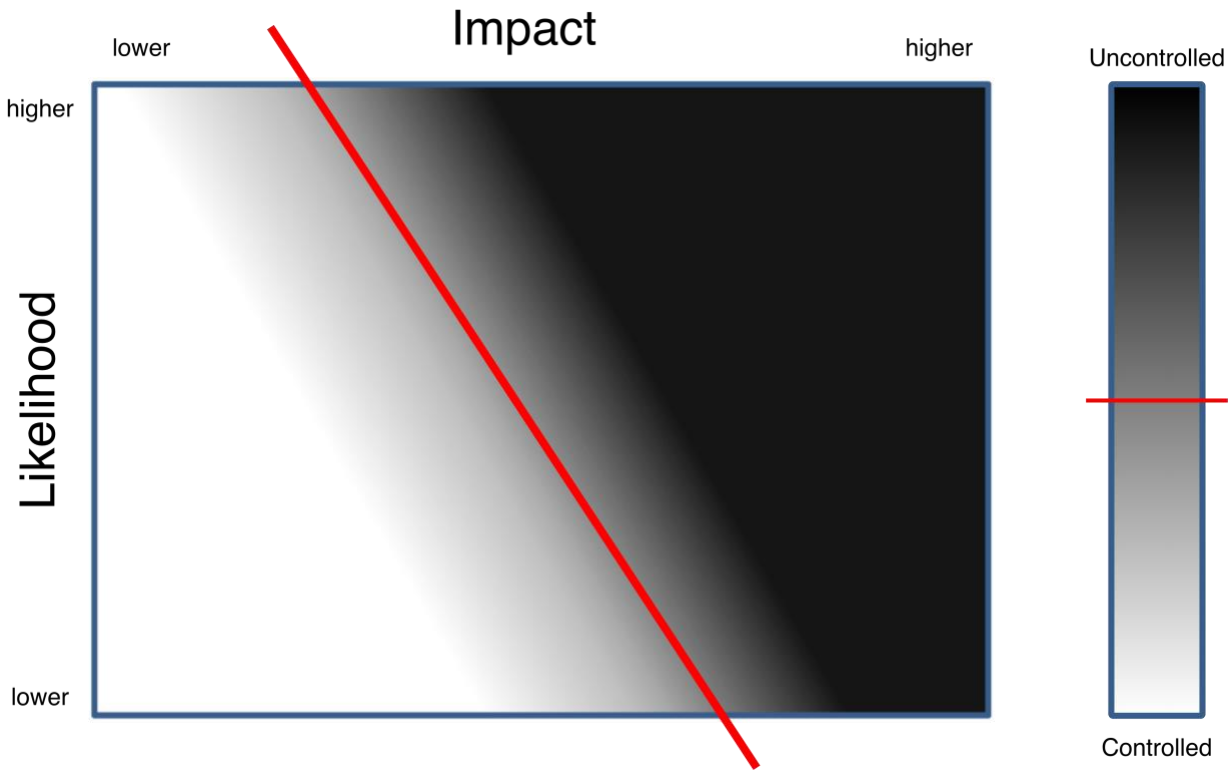
Since most rubrics either produce or work exclusively in a quantized space, this will be the most common representation of the risk space.

Note: The exact configuration of the space is determined by the quantization used by the likelihood and impact rubrics.

Risk Appetite - Continuous

When working in a continuous risk space, the risk appetite can be represented as a straight line bisecting the space.

This is illustrated in the following diagram.



The difficulty with this approach is that the risk appetite line is somewhat arbitrary.

This approach does however lend itself to programmatic processing of the threat candidates.

Risk Appetite - Quantized

When working with a quantized space, the risk appetite cannot always be shown as a simple line.

Consider the following diagram showing the NIST SP 800-30 [9] risk determination (table I-2).

likelihood \ level of impact	very low	low	moderate	high	very high
very high	very low	low	moderate	high	very high
high	very low	low	moderate	high	very high
moderate	very low	low	moderate	moderate	high
low	very low	low	low	low	moderate
very low	very low	very low	very low	low	low

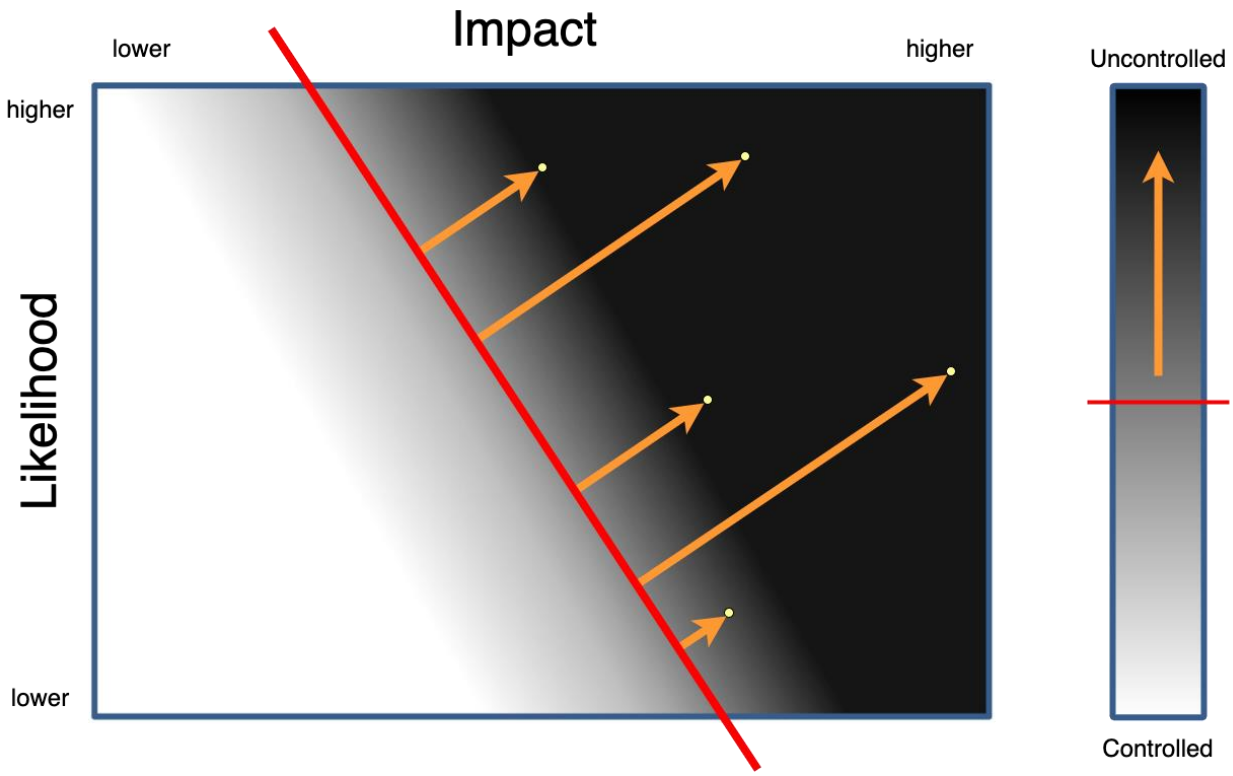
Based on the risk associated with the various combinations of likelihood and impact, it is clear that if an organization's risk appetite has a cutoff other than **high** or **very high** that a straight line does not describe the appetite. In these cases, the risk appetite should simply be documented using a clear statement, such as "all threats with a risk value of **high** or **very high** are considered to be uncontrolled," or by providing a diagram which highlights which risk values equate to an uncontrolled threat.

Most quantized spaces will not be a cleanly defined as NIST SP 800-30. For each combination of likelihood and impact rubric, a set of resultant risk rating will need to be determined and documented, prior to the slicing activity.

Threat Prioritization - Continuous

When prioritization of the uncontrolled threats is desired, and one is working within a continuous risk space, the magnitude of the normal from the risk appetite line to the location of the threat may be used to prioritize the uncontrolled threats.

This is illustrated in the following diagram.



Higher priority threats have larger normal values.

Threat Prioritization - Quantized

When working within a quantized risk space, the product of the upper end values of the quantization bands for the likelihood and impact may be used to generate a priority ordering.

This is illustrated in the following diagram which uses a CVSS [7] likelihood quantization and an ISO/SAE 21434 [8] impact quantization.

Likelihood	Impact: lower					Impact: higher
higher	0	10	20	30	40	50
	0	9	18	27	36	45
	0	8	16	24	32	40
	0	7	14	21	28	35
	0	6	12	18	24	30
	0	5	10	15	20	25
	0	4	8	12	16	20
	0	3	6	9	12	15
	0	2	4	6	8	10
	0	1	2	3	4	5
	0	0.1	0.2	0.3	0.4	0.5
lower	0	0	0	0	0	0

Since ISO/SAE 21434 does not specify the value ranges (bands) for the quantization, they have been mapped to align with the ones provided for CVSS.

Note: Because quantization reduces the resolution of the risk value, it will be less precise compared to the continuous approach. As a result, there is a greater likelihood that multiple threats will have the same priority.

Threat Candidate Slicing Template (NIST SP 800-30 Rubric)

The threat candidate slicing may be documented using the **AVCDL threat candidate slicing (SP 800-30) template** Microsoft Excel workbook [6] when the NIST SP 800-30 rubric is used.

Note: Other forms of documentation are permissible so long as they provide the information laid out in this document.

Note: Because of the amount of tailoring required to create a template specific to an organization's likelihood and impact rubrics (of which multiple may be used), only a template specific to NIST SP 800-30 is provided. This example should be sufficient for repurposing.

The workbook contains the following sheets:

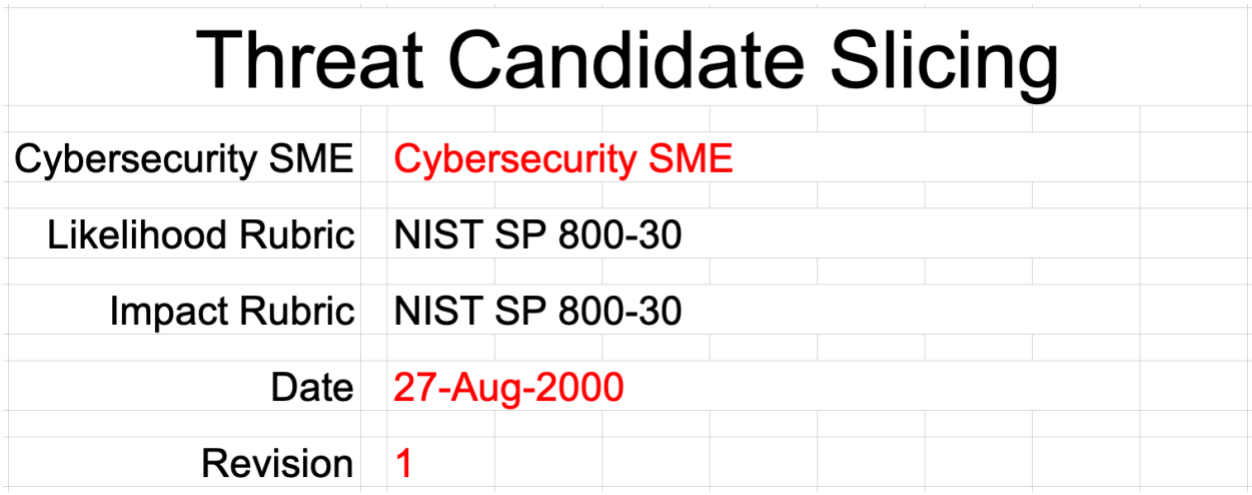
- Cover sheet
- Revision history
- Reference documents
- Slicing
- 800-30 quantization
- Legend
- Scratchpad

Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks and inter-sheet lookups may be attached to some of the cells which enables the use of drop-down lists and auto-population.

Cover Sheet

The **cover sheet** of the workbook is shown below:



Threat Candidate Slicing	
Cybersecurity SME	Cybersecurity SME
Likelihood Rubric	NIST SP 800-30
Impact Rubric	NIST SP 800-30
Date	27-Aug-2000
Revision	1

Fields to be completed are shown in **red**.

Cybersecurity SME

This is the cybersecurity subject matter expert creating the uncontrolled threats list.

Likelihood Rubric

This is the name of the rubric used to determine the threat candidate's likelihood.

Impact Rubric

This is the name of the rubric used to determine the threat candidate's impact.

Date

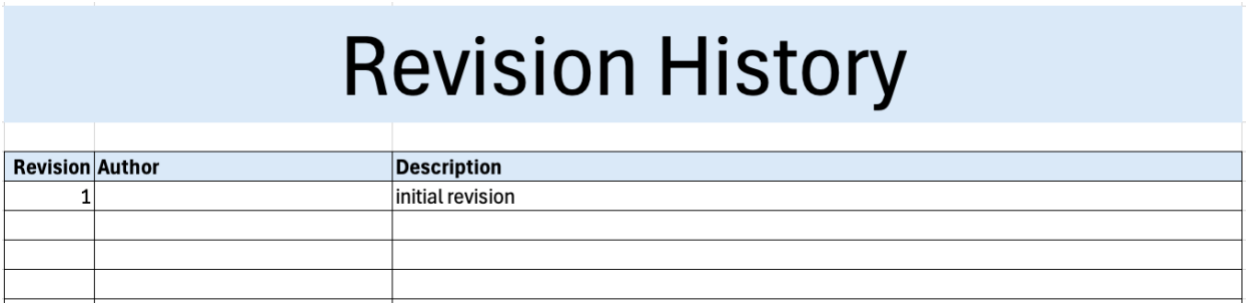
This is the date when the document was created or updated. The date should be updated whenever the document is updated.

Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

Revision History

The **revision history** sheet of the workbook is shown below:



Revision History

Revision	Author	Description
1		initial revision

Revision

The **revision** corresponds to that listed on the cover sheet.

Author

The **author** corresponds to the cybersecurity SME listed on the cover sheet.

Description

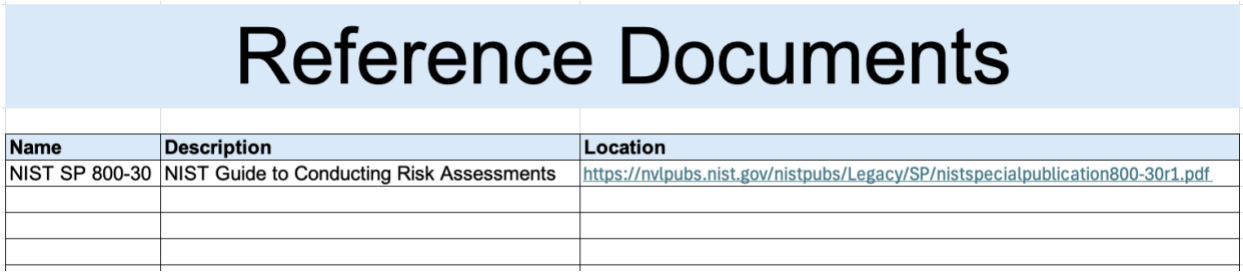
This is a brief description of changes made to the workbook since it was last updated.

Reference Documents

Note: These references are those necessary for the creation of the uncontrolled threat list.

Note: References to ranking and risking inputs should be included.

The **references** sheet of the workbook is shown below:



Reference Documents

Name	Description	Location
NIST SP 800-30	NIST Guide to Conducting Risk Assessments	https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf

Name

This is the name of the document being referenced.

Description

This is a brief description of the document being referenced.

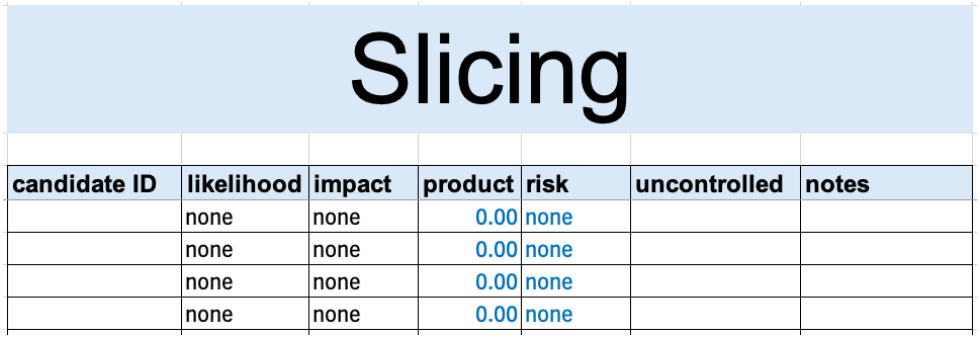
Note: In cases where the reference material is expressed in a form other than a document (for example, a web page), this should be noted.

Location

This is the location of the document being referenced. It may be a physical location or a URL.

Slicing

The **slicing** sheet of the workbook is shown below:



Slicing

candidate ID	likelihood	impact	product	risk	uncontrolled	notes
	none	none	0.00	none		
	none	none	0.00	none		
	none	none	0.00	none		
	none	none	0.00	none		

Candidate ID

This is the unique ID of the threat candidate.

Note: This value should be copied from the triage output providing input to this activity.

Likelihood

This is the threat candidate's likelihood as determined in the threat ranking activity.

Note: This value should be copied from the threat candidate ranking activity output.

Impact

This is the threat candidate's impact as determined in the threat risking activity.

Note: This value should be copied from the threat candidate risking activity output.

Product

This is the threat candidate risk determined as the product of the likelihood and impact values.

Note: This field is auto-populated.

Risk

This is the threat candidate's quantized risk associated with the product value.

Note: This field is auto-populated.

Uncontrolled

This field indicates whether the threat candidate is determined to be uncontrolled based on the organization's risk appetite.

Note: This field is drop-down.

Notes

This is a general notes field.

800-30 Quantization

This sheet provides translation between the likelihood / impact quantized representations and the associated values allowing their product to generate the desired quantized risk space values.

Note: This sheet (based on NIST SP 800-30) is complete as shown.

The **800-30 quantization** sheet of the workbook is shown below:

800-30 Rubric Quantization

min value	likelihood label	likelihood factor	impact label	impact factor	description	notes
0.0000	none	0.00	none	0.00	used to enable automation	DO NOT REMOVE THIS ENTRY
0.0001	very low	3.00	very low	0.40		
20.0000	low	5.00	low	4.50		
50.0000	moderate	8.00	moderate	6.50		
80.0000	high	9.60	high	8.35		
95.0000	very high	10.00	very high	10.00		

Note: A true zero (none) entry is included in order to support automation.

Min value

This is the minimum value of the quantization band.

Note: The second entry's value is set to be slightly greater than the **'none'** band.

Note: The values of this field are assigned in order to generate the quantized values specified in NIST SP 800-30 table I-2.

Likelihood label

This is the name of the likelihood quantization band.

Note: This column is used to populate **likelihood** fields on the **slicing** sheet. It is used for both drop-down lists and computed fields.

Likelihood factor

This value is used to generate the risk value when multiplied by the **impact factor**.

Note: The values of this field are assigned in order to generate risk values specified in NIST SP 800-30 table G-5.

Impact label

This is the name of the impact quantization band.

Note: This column is used to populate **impact** fields on the **slicing** sheet. It is used for both drop-down lists and computed fields.

Impact factor

This value is used to generate the risk value when multiplied by the **likelihood factor**.

Note: The values of this field are assigned in order to generate risk values specified in NIST SP 800-30 table H-3.

Description

This is the description of the quantization band.

Notes

This is a general notes field.

Legend

This sheet provides fixed values for various drop-down fields.

uncontrolled
yes
no

uncontrolled

This is used to populate the **uncontrolled** field of the **slicing** sheet.

Scratchpad

This sheet illustrates how the likelihood and impact rubric quantizations can be used to generate an arbitrary risk value.

Note: This sheet is based on NIST SP 800-30.

The first two tables of the **800-30 quantization** sheet of the workbook are shown below:

		0	0.0001	20	50	80	95
		0	0.4	4.5	6.5	8.35	10
95	10	0.00	4.00	45.00	65.00	83.50	100.00
80	9.6	0.00	3.84	43.20	62.40	80.16	96.00
50	8	0.00	3.20	36.00	52.00	66.80	80.00
20	5	0.00	2.00	22.50	32.50	41.75	50.00
0.0001	3	0.00	1.20	13.50	19.50	25.05	30.00
0	0	0.00	0.00	0.00	0.00	0.00	0.00

		none	very low	low	moderate	high	very high
very high		none	very low	low	moderate	high	very high
high		none	very low	low	moderate	high	very high
moderate		none	very low	low	moderate	moderate	high
low		none	very low	low	low	low	moderate
very low		none	very low	very low	very low	low	low
none		none	none	none	none	none	none

Note: A true zero (none) entry is included in order to support automation.

Elaboration

In these tables, as with other risk diagrams, the **likelihood** is shown on the left and **impact** across the top. These values are the minimums for the quantization ranges.

The green bands represent the factor values which when multiplied together generate the field of the table. These are the raw risk values.

Note: The raw risk values can be used to prioritize the uncontrolled threats.

The bottom table shows the raw risk values mapped to the quantization labels.

Note: The cell colors have been applied manually to allow visual inspection of the table to ensure that the factors are producing the desired result.

Note: The values of this field are assigned in order to generate the qualitative values specified in NIST SP 800-30 table I-2.

Note: The values for the factors (top table in green) are determined iteratively.

The following table on the sheet is used to assist in verifying specific combinations of **likelihood** and **impact**.

likelihood	impact		product	risk
none	high		0.00	none
very low	moderate		24.00	low
moderate	low		40.00	low
moderate	moderate		64.00	moderate
high	very high		96.00	very high
very high	very high		100.00	very high

Note: The **likelihood** and **impact** fields are drop-downs, whereas the **product** and **risk** fields are computed.

Exit Criteria

This procedure is considered complete once the **uncontrolled threats** list has been generated and the individual threats are entered into the issue tracking system.

Additionally, the threat report should be entered into the DMS.

References

1. **AVCDL** (AVCDL primary document)
2. **Theat Prioritization Plan** (AVCDL secondary document)
3. **Threat Prioritization – Threat Candidate Ranking Procedure** (AVCDL tertiary document)
4. **Threat Prioritization – Threat Candidate Risking Procedure** (AVCDL tertiary document)
5. **AVCDL Background Material** (AVCDL elaboration document)
6. **AVCDL threat candidate slicing (SP 800-30) template** (AVCDL template)
7. **Common Vulnerability Scoring System** https://www.first.org/cvss/
8. **ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering** https://www.iso.org/standard/70918.html
9. **NIST SP 800-30 r1 – Guide to Conducting Risk Assessments** http://dx.doi.org/10.6028/NIST.SP.800-30r1
10. **Postmarket Management of Cybersecurity in Medical Devices** https://www.fda.gov/regulatory-information/search-fda-guidancedocuments/postmarket-management-cybersecurity-medical-devices